CloudShield Technologies: Executive Cybersecurity Governance, Risk & Compliance Assessment Report

NIST CSF 2.0 Aligned Portfolio Assessment

Independent Portfolio Project: Simulated Organization | 2026

Prepared by: Elizabeth Kapusa

Purpose: Demonstrate practical entry-level GRC skills in risk assessment, control testing, policy development, remediation tracking, third-party risk, and executive reporting.

CloudShield Technologies: Executive GRC Assessment

1. Executive Summary

CloudShield Technologies is a simulated growing SaaS organization with approximately 120 employees, a remote/hybrid workforce, Microsoft Azure infrastructure, Microsoft 365, GitHub, a customer-facing application, a PostgreSQL customer database, and third-party SaaS providers. This independent portfolio assessment evaluates selected cybersecurity governance and control risks using NIST Cybersecurity Framework (CSF) 2.0 concepts and selected NIST SP 800-53 control areas.

The assessment identified five priority risks. Four were initially rated High and one was reduced to Medium after considering existing backup controls. The most significant themes were privileged-access governance, MFA and workload identity, vulnerability-remediation discipline, third-party assurance, and recovery-process evidence.

The assessment shows a risk-based approach: identify the condition, evaluate likelihood and impact, review existing controls, test operating effectiveness, define treatment, assign ownership, establish evidence requirements, and retest before reducing residual risk.

2. Scope and Environment

Area	In-Scope Environment
Organization	CloudShield Technologies: simulated SaaS company, approximately 120 employees.
Workforce	Remote/hybrid workforce with varying levels of business and privileged access.
Technology	Microsoft Azure, Microsoft 365, GitHub, customer-facing application, PostgreSQL database, third-party SaaS.
Assessment Focus	Identity/access, vulnerability management, backup/recovery, third-party risk, governance, evidence, and remediation.
Framework Lens	NIST CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond, Recover; selected SP 800-53 control concepts.

3. Assessment Methodology

A qualitative 5×5 risk method was used for the portfolio. Likelihood and impact are each scored from 1 to 5. Risk score equals Likelihood × Impact.

Score	Rating
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

Control testing distinguishes control design from operating effectiveness. Planned remediation alone does not reduce residual risk, risk is reduced only when corrective actions are implemented, evidenced, and successfully retested.

4. Executive Risk Register

ID	Risk	Inherent / Current Rating	Treatment	Owner
GRC-001	Inadequate Privileged Account Offboarding	High: 16/25	Mitigate	IT / Security Manager
GRC-002	Incomplete MFA Enforcement for Privileged Accounts	High: 16/25	Mitigate	IAM / Security
GRC-003	Overdue Production Vulnerability / No Remediation SLA	High: 16/25	Mitigate	Application / Security Engineering
GRC-004	Inadequate Backup Restoration Testing	Medium residual: 8/25 after existing controls	Mitigate	Infrastructure / Business Continuity

GRC-005	Inadequate Third-Party Security Review	High: 16/25	Mitigate	Vendor Risk / Security

5. Detailed Risk Findings

GRC-001: Privileged Account Offboarding

A terminated engineer's Microsoft 365 account was disabled on the termination date, but an Azure privileged account remained active for 19 days and recorded three successful authentications after termination. The investigation did not establish that customer data was accessed or altered. CloudShield also lacked evidence of a formal quarterly privileged-access review.

Assessment: Likelihood 4 × Impact 4 = 16/25, High. The risk remains High because privileged access persisted after termination and post-termination authentication occurred. Evidence of risk is not treated as evidence of a confirmed breach.

Treatment: automate or formalize HR-to-IT offboarding, immediately revoke all access at termination, maintain a privileged-account inventory, perform recurring privileged-access reviews, and alert on post-termination access.

GRC-002: Privileged Access & MFA

Two privileged identities were outside the standard MFA control: azure-admin-legacy, a human production administrator, and svc-deployment-prod, a non-human deployment identity using a long-lived broadly privileged secret. No formal exception package was available.

Control conclusion: Fail remediation required. MFA should be enforced for the interactive human administrator. The automated identity should be migrated to an appropriate managed/workload identity or other approved non-interactive authentication design, with least privilege, credential reduction, restricted use, and monitoring. Residual risk remains High until implementation and retesting.

GRC-003: Vulnerability Management

A High-severity vulnerability affecting an internet-facing production application remained unresolved for 47 days. Vulnerability scanning existed, but CloudShield had no formal severity-based remediation standard.

Treatment established by the portfolio standard: Critical vulnerabilities target remediation within 24 hours; High within 7 calendar days; Medium within 30 days; Low within 90 days. Overdue findings

require escalation and, where remediation cannot be completed, a documented time-limited exception with compensating controls, owner, approval, and remediation plan.

GRC-004: Backup & Recovery

Daily PostgreSQL backups existed, but no documented restoration test had been performed for 11 months. A simulated restoration test restored the database in 2 hours 18 minutes against a 4-hour RTO and used a backup 6 hours old against a 24-hour RPO.

Control conclusion: Pass with Observation / Needs Improvement. The recovery capability worked, but the runbook contained an incorrect command, and successful completion depended on engineer knowledge. Remediation requires correcting and peer-reviewing the runbook, quarterly documented restoration tests, retained evidence, and a retest using the corrected procedure.

GRC-005: Third-Party Risk

DataFlow Analytics, a simulated high-criticality analytics vendor, demonstrated generally reasonable technical controls but supplied an 18-month-old SOC 2 Type II report, used an unreviewed subcontractor capable of processing CloudShield data, and stated a 72-hour incident-notification period while CloudShield's target is 24 hours.

Decision: Approve with Conditions. Require current assurance evidence, complete subprocessor due diligence, and resolve the incident-notification requirement. Escalate toward rejection or replacement if the vendor refuses remediation, cannot provide adequate assurance, or the subprocessor review identifies unacceptable risk.

6. NIST CSF 2.0 Current vs. Target Profile

The portfolio uses a 1–4 implementation scale for internal assessment only: 1 Initial, 2 Developing, 3 Defined, 4 Managed. This scale is not presented as an official NIST Implementation Tier.

CSF Function	Current	Target	Primary Gap
GOVERN	1.5	4	Risk-management policy, remediation governance, and supply-chain risk.
IDENTIFY	2.0	4	Asset/risk understanding and

			accountable ownership.
PROTECT	1.5	4	Identity, privileged access, MFA, and vulnerability remediation.
DETECT	2.0	4	Monitoring and event analysis for privileged activity.
RESPOND	2.0	4	Incident analysis, escalation, and documented response evidence.
RECOVER	2.0	4	Repeatable recovery testing and validated recovery procedures.

7. Control Testing Summary

Control Test	Result	Key Conclusion	Retest
Privileged offboarding / access	Deficiency identified	Privileged access persisted 19 days after termination; formal review evidence absent.	Yes
Privileged MFA / workload identity	Fail	Human MFA exclusion and insecure service-account design require remediation.	Yes
Vulnerability remediation governance	Fail / control gap	Scanning existed without defined remediation SLAs or exception governance.	Yes

Backup restoration	Pass with Observation	RTO/RPO achieved; runbook and testing cadence need improvement.	Yes
Third-party security review	Conditional approval	Technical controls generally reasonable; assurance, subprocessor, and notification gaps remain.	Yes

8. Prioritized Remediation Roadmap

Priority	Action	Linked Risk	Success Evidence
1	Immediately protect or remove inappropriate privileged access; enforce MFA for interactive admins.	GRC-001 / GRC-002	Disablement timestamps, MFA enforcement evidence, privileged inventory, review record.
2	Separate human admin identity from automation; migrate deployment authentication and reduce privilege.	GRC-002	Workload identity configuration, old-secret revocation, role assignments, monitoring evidence.
3	Implement severity-based vulnerability remediation and exception governance.	GRC-003	Standard, tickets, due dates, exception records, clean rescans / closure evidence.
4	Correct recovery runbook and establish quarterly restore testing.	GRC-004	Corrected runbook, restore logs, RTO/RPO results, independent

			retest.
5	Complete DataFlow assurance and subprocessor review; resolve incident-notification term.	GRC-005	Current assurance, subprocessor assessment, contract/DPA or approved risk acceptance.

9. Management Recommendations

- Create a recurring governance cadence to review High risks, overdue remediation, exceptions, and retest status.
- Require evidence-based closure: corrective-action plans should remain open until implementation and verification are complete.
- Maintain centralized inventories for privileged identities, critical assets, third parties, and security exceptions.
- Use risk-based metrics such as overdue vulnerabilities, privileged-access exceptions, vendor-review aging, restore-test results, and remediation SLA compliance.
- Perform periodic reassessment as CloudShield's systems, vendors, business processes, and threat environment change.

10. Portfolio Deliverables

Artifact	Purpose
GRC Risk Register & NIST CSF Assessment Workbook	Central risk, control, evidence, and CSF posture tracking.
Access Control & Identity Management Policy	Formalizes least privilege, MFA, privileged access, lifecycle controls, reviews, and exceptions.
Privileged Access & MFA Control Assessment	Tests GRC-002 and distinguishes human vs. non-human identity control design.
Vulnerability Management & Remediation Standard	Defines severity-based timelines, escalation, exceptions, evidence, and closure.
Backup Restoration Control Test Report	Tests recovery capability, RTO/RPO,

	documentation quality, and retest requirements.
Third-Party Vendor Security Risk Assessment	Demonstrates vendor due diligence, assurance review, conditional approval, and remediation.

11. Overall Conclusion

CloudShield's simulated assessment shows a developing cybersecurity governance environment with useful technical controls but inconsistent governance, evidence, review cadence, and exception management. The highest-value improvements are to strengthen privileged identity lifecycle controls, formalize vulnerability remediation, mature third-party assurance, and make recovery testing repeatable and evidence-driven.

The portfolio demonstrates practical GRC work across risk assessment, NIST CSF profiling, control design and testing, policy/standard development, remediation planning, third-party risk, business continuity, and executive communication. All organization, vendor, account, and test scenarios in this project are fictional and were created solely for portfolio demonstration.